

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC BÁCH KHOA
KHOA KHOA HỌC VÀ KỸ THUẬT MÁY TÍNH



Mật mã và An ninh mạng (CO3069)

Bảo mật Internet vạn vật (Internet of Things - IoT) & triển khai các biện pháp đối phó nhằm bảo mật Internet vạn vật

Giảng viên hướng dẫn: Nguyễn Cao Đạt

STT	Họ và tên	MSSV	Ngành
1	Nguyễn Triều Vĩ	23xxxxx	Kỹ thuật máy tính
2	Nguyễn Mai Huy Phát	2312589	Khoa học máy tính

Mục lục

1	GIỚI THIỆU	1
1.1	Lý do chọn đề tài	1
1.2	Mục tiêu nghiên cứu	1
1.3	Đối tượng và phạm vi nghiên cứu	1
1.4	Nội dung chính của báo cáo	1
2	CƠ SỞ LÝ THUYẾT	3
2.1	Tổng quan về Internet of Things (IoT)	3
2.1.1	Định nghĩa và đặc điểm	3
2.1.2	Thách thức về an ninh mạng trong IoT	3
2.2	Giao thức MQTT (Message Queuing Telemetry Transport)	3
2.2.1	Vấn đề bảo mật của MQTT mặc định	3
2.3	Giao thức Transport Layer Security (TLS) 1.2	3
2.4	Mutual TLS (M-TLS) và Hạ tầng khóa công khai (PKI)	4
2.4.1	Mutual TLS (Xác thực hai chiều)	4
2.5	Hệ thống phát hiện xâm nhập (IDS) và Suricata	5
2.5.1	Cơ chế hoạt động của Suricata	5
3	PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG	6
3.1	Yêu cầu hệ thống	6
3.2	Kiến trúc tổng thể của hệ thống	6
3.3	Thiết kế các lớp phòng thủ chiều sâu	6
3.3.1	Lớp 1: Thiết kế cơ chế mã hóa đường truyền (TLS)	6
3.3.2	Lớp 2: Thiết kế hệ thống xác thực thiết bị (Mutual TLS)	6
3.3.3	Lớp 3: Thiết kế hệ thống phát hiện xâm nhập (Suricata IDS)	7
3.4	Quy trình luân chuyển dữ liệu bảo mật	7
4	HIỆN THỰC VÀ ĐÁNH GIÁ	8
4.1	Môi trường triển khai	8
4.2	Hiện thực các thành phần hệ thống	8
4.2.1	Cấu hình hạ tầng khóa công khai (PKI)	8
4.2.2	Cấu hình Mosquitto Gateway (M-TLS)	8
4.2.3	Xây dựng Sensor Node bảo mật	8
4.3	Kết quả đánh giá và Thử nghiệm	9
4.3.1	Kịch bản 1: Kết nối hợp lệ và Mã hóa dữ liệu	9
4.3.2	Kịch bản 2: Truy cập trái phép (Không có chứng chỉ)	9
4.3.3	Kịch bản 3: Phát hiện hành vi quét cổng (Port Scanning)	10
4.4	Phân tích hiệu năng và Độ tin cậy	10
5	KẾT LUẬN	11
5.1	Những kết quả đã đạt được	11
5.2	Ưu điểm và Nhược điểm	11
5.2.1	Ưu điểm	11
5.2.2	Nhược điểm	11
5.3	Hướng phát triển của đề tài	11



Tài liệu tham khảo	13
Phụ lục	14

1 GIỚI THIỆU

1.1 Lý do chọn đề tài

Trong kỷ nguyên Công nghiệp 4.0, Internet vạn vật (IoT) đã trở thành một thành phần cốt lõi trong nhiều lĩnh vực từ sản xuất thông minh đến y tế và nhà ở. Tuy nhiên, sự bùng nổ về số lượng thiết bị cũng kéo theo những thách thức nghiêm trọng về an ninh mạng. Các thiết bị IoT thường có tài nguyên phần cứng hạn chế, dẫn đến việc thiếu hụt các cơ chế bảo mật mạnh mẽ, khiến chúng trở thành mục tiêu hàng đầu cho các cuộc tấn công như nghe lén, giả mạo dữ liệu và từ chối dịch vụ (DoS).

Là sinh viên chuyên ngành kỹ thuật tại Trường Đại học Bách khoa TP.HCM, nhóm nhận thấy việc xây dựng một hệ thống cổng kết nối (Gateway) bảo mật là nhiệm vụ cấp thiết để bảo vệ dữ liệu từ các nút cảm biến trước khi truyền lên hệ thống quản lý tập trung. Đề tài "**Bảo mật Internet vạn vật triển khai các biện pháp đối phó nhằm bảo mật IoT**" được lựa chọn nhằm nghiên cứu và thực thi các giải pháp phòng thủ chiều sâu (Defense-in-Depth) hiện đại.

1.2 Mục tiêu nghiên cứu

Mục tiêu cốt lõi của bài tập lớn này là thiết lập một môi trường IoT an toàn thông qua việc kết hợp giữa mật mã học và hệ thống giám sát xâm nhập:

- **Đảm bảo tính bí mật và toàn vẹn:** Sử dụng giao thức TLS 1.2 để mã hóa đường truyền, ngăn chặn hành vi đánh cắp thông tin trên đường truyền mạng.
- **Xác thực định danh thiết bị:** Triển khai cơ chế Mutual TLS (M-TLS) để đảm bảo chỉ những thiết bị sở hữu chứng chỉ số hợp lệ mới có thể kết nối vào hệ thống.
- **Giám sát chủ động:** Tích hợp hệ thống phát hiện xâm nhập Suricata nhằm nhận diện sớm các hành vi thám thính và tấn công vào Gateway.

1.3 Đối tượng và phạm vi nghiên cứu

- **Đối tượng nghiên cứu:** Giao thức truyền tin MQTT (Message Queuing Telemetry Transport), mô hình hạ tầng khóa công khai (PKI), và các bộ quy tắc phát hiện xâm nhập của Suricata IDS.
- **Phạm vi triển khai:** Hệ thống được mô phỏng hoàn toàn trên môi trường Linux (WSL2) với sự kết hợp của các công cụ mã nguồn mở: Mosquitto Broker, Python (cho Sensor Node), Suricata và Wireshark để phân tích dữ liệu thực nghiệm.

1.4 Nội dung chính của báo cáo

Báo cáo kỹ thuật được chia làm 5 chương chính theo quy định:

- **Chương 1 - Giới thiệu:** Trình bày lý do chọn đề tài, mục tiêu và phạm vi nghiên cứu.
- **Chương 2 – Cơ sở lý thuyết:** Hệ thống hóa các kiến thức về MQTT, mật mã học (TLS/M-TLS) và cơ chế hoạt động của IDS.

- **Chương 3 – Phân tích và thiết kế:** Mô tả kiến trúc hệ thống và quy trình thiết kế các lớp phòng thủ.
- **Chương 4 - Hiện thực và đánh giá:** Trình bày chi tiết quá trình cài đặt, cấu hình và kết quả thử nghiệm thực tế thông qua các kịch bản tấn công giả lập.
- **Chương 5 - Kết luận:** Tổng kết các kết quả đạt được, đánh giá ưu/nhược điểm và đề xuất hướng phát triển cho hệ thống.

2 CƠ SỞ LÝ THUYẾT

2.1 Tổng quan về Internet of Things (IoT)

2.1.1 Định nghĩa và đặc điểm

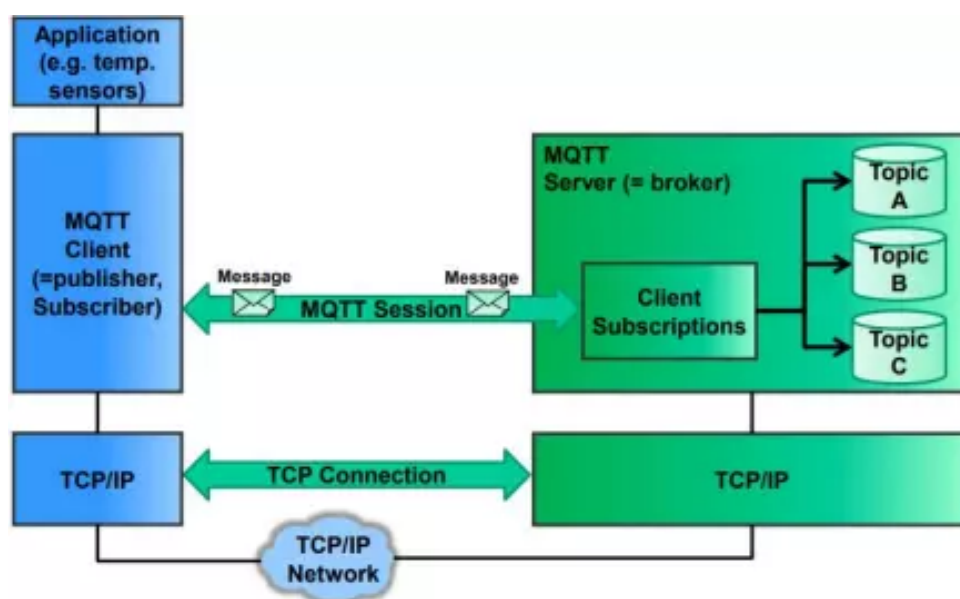
Internet of Things (IoT) là mạng lưới các thiết bị vật lý được tích hợp cảm biến và phần mềm để trao đổi dữ liệu qua Internet. Các thiết bị này thường có tài nguyên phần cứng hạn chế, gây khó khăn cho việc triển khai bảo mật phức tạp.

2.1.2 Thách thức về an ninh mạng trong IoT

Hệ thống IoT đối mặt với ba nhóm nguy cơ chính: thiết bị đầu cuối thiếu xác thực, dữ liệu trên đường truyền bị nghe lén, và hạ tầng Gateway dễ bị tấn công từ chối dịch vụ (DoS).

2.2 Giao thức MQTT (Message Queuing Telemetry Transport)

MQTT là giao thức dựa trên mô hình Xuất bản/Dăng ký (Publish/Subscribe), hiện là tiêu chuẩn cho truyền tin IoT.



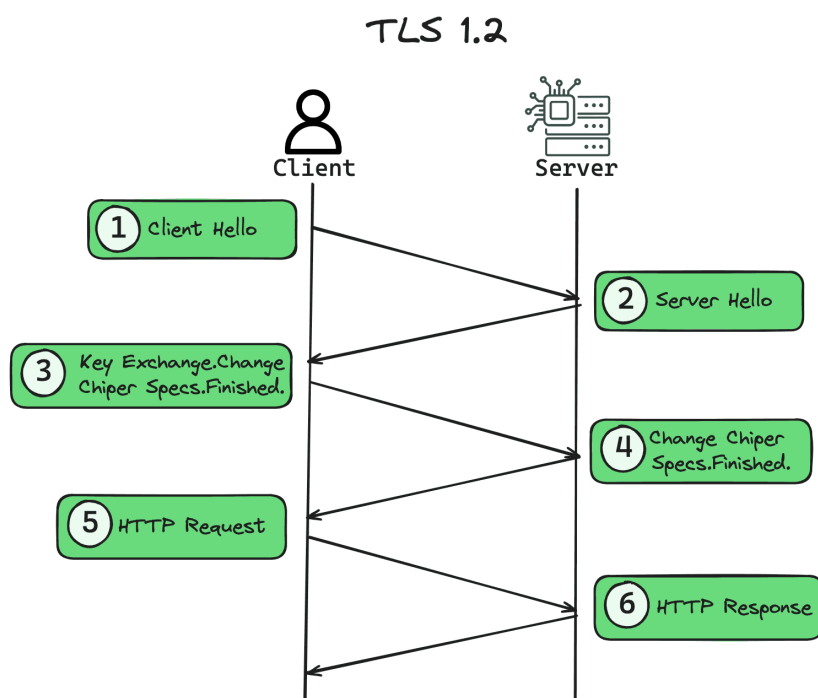
Hình 1: Mô hình giao tiếp Publish/Subscribe trong giao thức MQTT

2.2.1 Vấn đề bảo mật của MQTT mặc định

Mặc định, MQTT sử dụng cổng 1883 và không mã hóa, khiến Payload dễ bị đánh cắp bởi các công cụ bắt gói tin. Việc triển khai qua cổng 8883 với lớp bảo mật TLS là yêu cầu bắt buộc để bảo vệ dữ liệu.

2.3 Giao thức Transport Layer Security (TLS) 1.2

TLS là giao thức mật mã cung cấp truyền thông an toàn qua mạng thông qua mã hóa và xác thực.

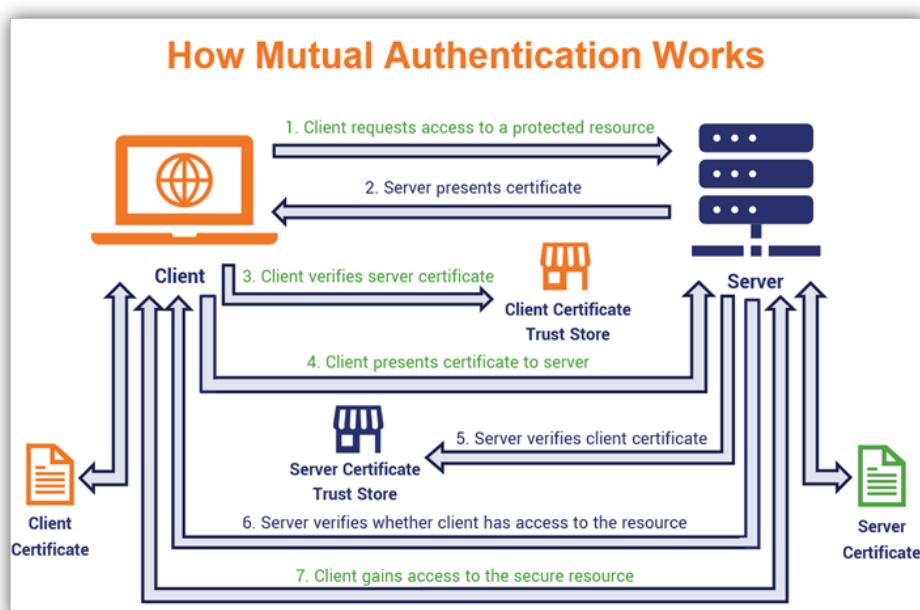


Hình 2: Quy trình bắt tay (Handshake) trong giao thức TLS 1.2

2.4 Mutual TLS (M-TLS) và Hạ tầng khóa công khai (PKI)

2.4.1 Mutual TLS (Xác thực hai chiều)

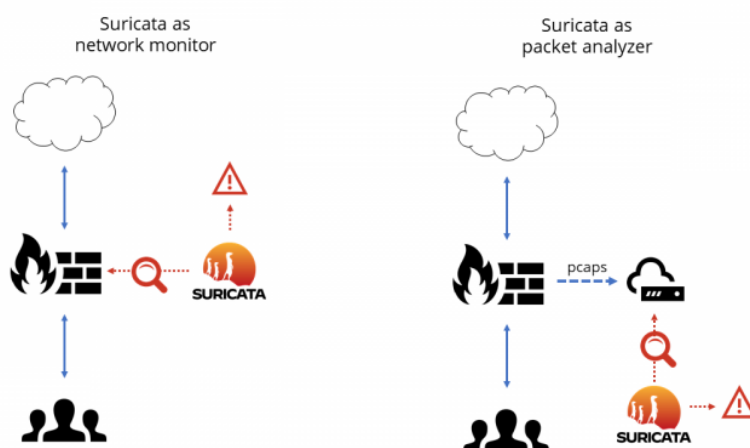
Trong mô hình M-TLS, cả Server và Client đều phải trình diện chứng chỉ số hợp lệ để xác thực danh tính lẫn nhau, đảm bảo chỉ thiết bị được cấp phép mới có thể kết nối.



Hình 3: Cấu trúc hệ thống PKI và mối quan hệ giữa Root CA với các chứng chỉ thành phần

2.5 Hệ thống phát hiện xâm nhập (IDS) và Suricata

IDS là ứng dụng giám sát mạng để phát hiện các hoạt động độc hại thông qua đối soát dấu hiệu (Signature-based).



Hình 4: Vị trí và cơ chế giám sát của Suricata IDS trong mô hình Gateway

2.5.1 Cơ chế hoạt động của Suricata

Suricata phân tích lưu lượng mạng thực tế và kích hoạt cảnh báo nếu gói tin khớp với các quy tắc đã định nghĩa, chẳng hạn như nhận diện cờ SYN trong các cuộc quét cổng.

3 PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

3.1 Yêu cầu hệ thống

Dựa trên các thách thức về an ninh mạng IoT đã phân tích ở Chương 2, hệ thống cần đáp ứng các yêu cầu kỹ thuật sau:

- **Tính bí mật (Confidentiality):** Dữ liệu từ Sensor gửi về Gateway phải được mã hóa để ngăn chặn hành vi nghe lén.
- **Tính xác thực (Authentication):** Chỉ các thiết bị cảm biến được cấp phép mới có quyền gửi dữ liệu vào hệ thống.
- **Tính sẵn sàng và Giám sát (Availability & Monitoring):** Hệ thống phải có khả năng nhận diện các hành vi bất thường và tấn công mạng nhắm vào Gateway.

3.2 Kiến trúc tổng thể của hệ thống

Hệ thống được thiết kế theo mô hình ba lớp chức năng tương ứng với dự án IoT-Security-BTL7.

Hình 5: Sơ đồ kiến trúc hệ thống IoT Gateway bảo mật 3 lớp

** Gợi ý hình ảnh: Vẽ sơ đồ khối gồm Sensor (Python), IoT Gateway (Mosquitto) và IDS (Suricata). Thể hiện luồng dữ liệu đi qua cổng 8883 và Suricata giám sát tại giao diện mạng.*

3.3 Thiết kế các lớp phòng thủ chiều sâu

3.3.1 Lớp 1: Thiết kế cơ chế mã hóa đường truyền (TLS)

Để đảm bảo tính bí mật, hệ thống sử dụng giao thức TLS 1.2 qua cổng 8883.

- **Giao thức:** TLS 1.2.
- **Cổng kết nối:** 8883 (Secure MQTT).
- **Mục tiêu:** Đóng gói toàn bộ gói tin MQTT Payload bên trong các bản tin TLS để ngăn chặn các cuộc tấn công đánh cắp dữ liệu.

3.3.2 Lớp 2: Thiết kế hệ thống xác thực thiết bị (Mutual TLS)

Đây là lớp bảo mật then chốt sử dụng hạ tầng khóa công khai (PKI) để định danh thiết bị.

- **Root CA:** Được tạo ra để đóng vai trò thực thể tin cậy duy nhất trong hệ thống.
- **Cấp phát chứng chỉ:** Root CA sẽ thực hiện ký số (Sign) cho cả chứng chỉ của Broker (Server) và Sensor (Client).
- **Cơ chế kiểm soát:** Khi Sensor kết nối, Broker sẽ yêu cầu thiết bị trình diện chứng chỉ (`require_certificate true`). Nếu chứng chỉ không được ký bởi Root CA hợp lệ, kết nối sẽ bị từ chối ngay lập tức.

3.3.3 Lớp 3: Thiết kế hệ thống phát hiện xâm nhập (Suricata IDS)

Lớp cuối cùng tập trung vào việc giám sát và cảnh báo sớm.

- **Vị trí đặt:** Suricata được cấu hình để lắng nghe trực tiếp trên giao diện mạng vòng lặp (*loopback - lo*), nơi luân chuyển traffic nội bộ giữa các thành phần trên WSL2.
- **Thiết kế luật (Rules):** Xây dựng các quy tắc nhận diện gói tin dựa trên cờ TCP (Flags). Cụ thể, hệ thống tập trung nhận diện gói tin TCP SYN (yêu cầu kết nối) lặp lại liên tục từ một nguồn, dấu hiệu đặc trưng của hành vi quét cổng (Port Scan).

3.4 Quy trình luân chuyển dữ liệu bảo mật

Dữ liệu từ lúc sinh ra tại Sensor Node đến khi được xử lý tại Gateway trải qua quy trình sau:

1. Sensor Node thực hiện bắt tay (Handshake) và trình diện chứng chỉ Client cho Broker.
2. Broker xác minh chứng chỉ thông qua Root CA lưu trữ cục bộ.
3. Sau khi xác thực thành công, kênh truyền TLS được thiết lập; dữ liệu MQTT được mã hóa và gửi đi.
4. Đồng thời, Suricata quét liên tục các gói tin đi qua cổng 8883 để đối soát với bộ luật phòng thủ.

4 HIỆN THỰC VÀ ĐÁNH GIÁ

4.1 Môi trường triển khai

Hệ thống được hiện thực trên môi trường ảo hóa nhằm mô phỏng thực tế một hạ tầng IoT Gateway. Các thông số kỹ thuật bao gồm:

- **Hệ điều hành:** Windows 11 tích hợp WSL2 (Ubuntu 24.04 LTS).
- **Phần mềm Broker:** Eclipse Mosquitto phiên bản 2.0.18.
- **Ngôn ngữ lập trình:** Python 3.12 với thư viện `paho-mqtt`.
- **Hệ thống IDS:** Suricata phiên bản 7.0.3 chạy ở chế độ SYSTEM mode.
- **Công cụ phân tích:** Wireshark v4.2.0 và `tcpdump`.

4.2 Hiện thực các thành phần hệ thống

4.2.1 Cấu hình hạ tầng khóa công khai (PKI)

Chúng tôi đã khởi tạo một hệ thống chứng chỉ số nội bộ bao gồm các thành phần:

- `ca.crt`: Chứng chỉ Root CA dùng để ký cho toàn hệ thống.
- `server.crt`, `server.key`: Bộ chứng chỉ và khóa bí mật cho Broker.
- `client.crt`, `client.key`: Bộ chứng chỉ và khóa bí mật cho Sensor Node.

4.2.2 Cấu hình Mosquitto Gateway (M-TLS)

Tệp cấu hình `mosquitto.conf` được thiết lập để bắt buộc xác thực hai chiều:

Listing 1: Cấu hình bảo mật trong `mosquitto.conf`

```
1 listener 8883
2 cafile /path/to/ca.crt
3 certfile /path/to/server.crt
4 keyfile /path/to/server.key
5 require_certificate true
6 use_identity_as_username true
```

4.2.3 Xây dựng Sensor Node bảo mật

Mã nguồn `iot_sensor.py` được hiện thực để nạp các chứng chỉ số trước khi thực hiện kết nối:

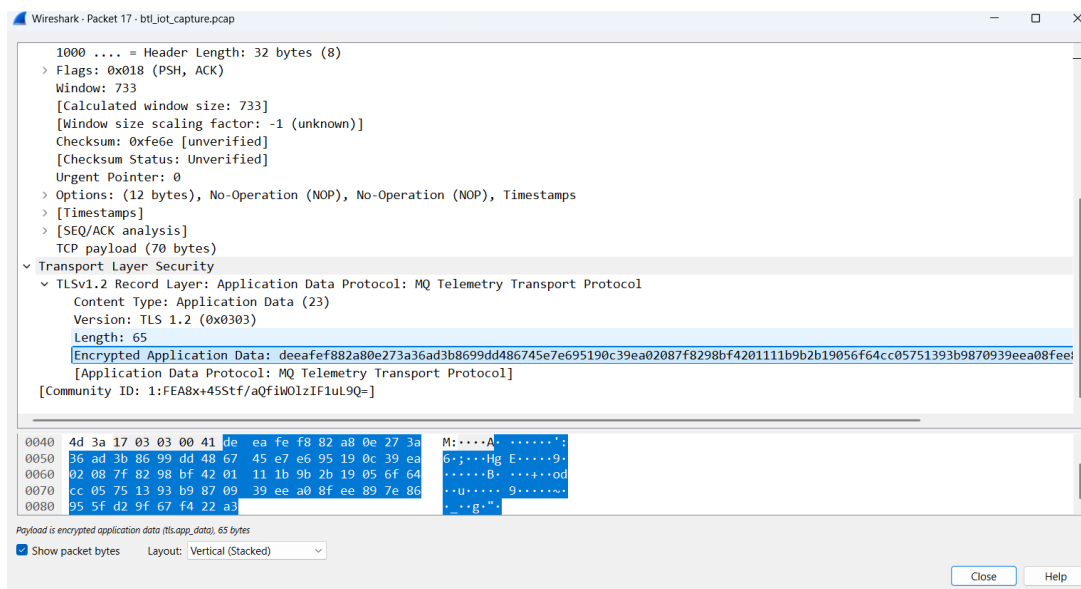
Listing 2: Đoạn mã nạp chứng chỉ TLS trong Python

```
1 client.tls_set(ca_certs="ca.crt",
2               certfile="client.crt",
3               keyfile="client.key",
4               tls_version=ssl.PROTOCOL_TLSv1_2)
5 client.connect("127.0.0.1", 8883)
```

4.3 Kết quả đánh giá và Thử nghiệm

4.3.1 Kịch bản 1: Kết nối hợp lệ và Mã hóa dữ liệu

Khi Sensor Node trình diễn đúng chứng chỉ, kết nối được thiết lập thành công. Qua phân tích Wireshark (Hình 7), toàn bộ dữ liệu MQTT đã được đóng gói trong lớp TLS 1.2.



Hình 6: Phân tích gói tin Application Data đã được mã hóa hoàn toàn

Dữ liệu thô (Payload) hiển thị dưới dạng các chuỗi nhị phân ngẫu nhiên, minh chứng cho việc ngăn chặn thành công hành vi nghe lén (Eavesdropping).

4.3.2 Kịch bản 2: Truy cập trái phép (Không có chứng chỉ)

Khi thực hiện kết nối từ một máy khách không có chứng chỉ hợp lệ, Broker lập tức ngắt kết nối. Nhật ký hệ thống ghi nhận lỗi xác thực chứng chỉ, khẳng định tính hiệu quả của lớp phòng thủ thứ hai (M-TLS).

Chứng chỉ không hợp lệ:

```
^Cchlorcale@LAPTOP-AACLUURG:~/BTL 7 Mật mã an ninh mạng/IoT-Security-BTL7/srcs/sensor$ mosquitto_sub -h localhost -p 8883 -t "hcmut/iot/#"  
Error: Protocol error  
chlorcale@LAPTOP-AACLUURG:~/BTL 7 Mật mã an ninh mạng/IoT-Security-BTL7/srcs/sensor$ mosquitto_sub -h localhost -p 8883 -t "hcmut/iot/#" --cafi  
le ../pkis/ca.crt  
Error: The connection was lost.
```

Broker ngắt kết nối:

```
chlorcale@LAPTOP-AACLUURG:~/BTL 7 Mật mã an ninh mạng/IoT-Security-BTL7/srcs/gateway$ mosquitto -c mosquitto.conf -v  
1777737954: mosquitto version 2.0.18 starting  
1777737954: Config loaded from mosquitto.conf.  
1777737954: Opening ipv4 listen socket on port 8883.  
1777737954: Opening ipv6 listen socket on port 8883.  
1777737954: mosquitto version 2.0.18 running  
1777737967: New connection from 127.0.0.1:45092 on port 8883.  
1777737967: OpenSSL Error[0]: error:0A000418:SSL routines:tls:alert unknown ca  
1777737967: Client <unknown> disconnected: Protocol error.  
1777738018: New connection from 127.0.0.1:35558 on port 8883.  
1777738018: OpenSSL Error[0]: error:0A0000C7:SSL routines:peer did not return a certificate  
1777738018: Client <unknown> disconnected: Protocol error.  
1777739894: New connection from 127.0.0.1:43265 on port 8883.  
1777739894: New client connected from 127.0.0.1:43265 as Sensor_Node_01 (p2, c1, k60, u'Sensor01').  
1777739894: No will message specified.  
1777739894: Sending CONNACK to Sensor_Node_01 (0, 0)  
1777739894: Received PUBLISH from Sensor_Node_01 (d0, q0, r0, m0, 'hcmut/iot/sensor/data', ... (16 bytes))  
1777739899: Received PUBLISH from Sensor_Node_01 (d0, q0, r0, m0, 'hcmut/iot/sensor/data', ... (16 bytes))  
1777739904: Received PUBLISH from Sensor_Node_01 (d0, q0, r0, m0, 'hcmut/iot/sensor/data', ... (16 bytes))  
1777739909: Received PUBLISH from Sensor_Node_01 (d0, q0, r0, m0, 'hcmut/iot/sensor/data', ... (16 bytes))  
1777739914: Received PUBLISH from Sensor_Node_01 (d0, q0, r0, m0, 'hcmut/iot/sensor/data', ... (16 bytes))  
1777739919: Received PUBLISH from Sensor_Node_01 (d0, q0, r0, m0, 'hcmut/iot/sensor/data', ... (16 bytes))
```

Hình 7: Phân tích log của 2 bên: xâm nhập trái phép và máy chủ

4.3.3 Kịch bản 3: Phát hiện hành vi quét cổng (Port Scanning)

Giả lập một cuộc tấn công thám thính bằng công cụ Nmap:

```
1 sudo nmap -sS -p 8883 127.0.0.1
```

Suricata IDS, với bộ luật sid:1000001, đã nhận diện chính xác các gói tin TCP SYN và ghi lại cảnh báo trong tệp fast.log:

```
1 05/02/2026-23:38:12.113405 [**] [1:1000001:1] Cảnh báo: Phát hiện quét cổng hoặc tấn công DoS vào MQTT  
[**] [Priority: 3] {TCP} 127.0.0.1:34937 -> 127.0.0.1:8883
```

4.4 Phân tích hiệu năng và Độ tin cậy

Việc triển khai thêm các lớp bảo mật (TLS/M-TLS) có làm tăng độ trễ trong quá trình bắt tay ban đầu (Handshake), tuy nhiên sau khi kết nối được thiết lập, việc truyền tải dữ liệu diễn ra ổn định với độ trễ không đáng kể đối với các ứng dụng giám sát nhiệt độ định kỳ. Hệ thống IDS Suricata vận hành hiệu quả trên WSL2 ở chế độ pcap mode, đảm bảo giám sát liên tục mà không gây quá tải cho CPU.

5 KẾT LUẬN

5.1 Những kết quả đã đạt được

Thông qua quá trình nghiên cứu và hiện thực đề tài "Bảo mật Internet vạn vật triển khai các biện pháp đối phó", nhóm đã hoàn thành các mục tiêu đề ra ban đầu:

- **Xây dựng thành công hạ tầng PKI nội bộ:** Khởi tạo Root CA và cấp phát chứng chỉ số cho các thực thể trong hệ thống, đảm bảo tính tin cậy cho toàn bộ mô hình.
- **Triển khai lớp bảo mật đường truyền và xác thực:** Hiện thực hóa giao thức TLS 1.2 kết hợp với cơ chế Mutual TLS (M-TLS) trên Broker Mosquitto, đảm bảo dữ liệu cảm biến được mã hóa và chỉ các thiết bị hợp lệ mới có thể truy cập.
- **Tích hợp hệ thống giám sát xâm nhập:** Vận hành Suricata IDS trên môi trường WSL2, xây dựng thành công bộ luật tùy chỉnh (`sid:1000001`) để phát hiện các hành vi thám thính và quét cổng từ công cụ Nmap nhắm vào cổng 8883.
- **Đánh giá thực nghiệm khách quan:** Sử dụng Wireshark và nhật ký hệ thống để chứng minh tính hiệu quả của các lớp phòng thủ trong việc chống nghe lén và phát hiện tấn công.

5.2 Ưu điểm và Nhược điểm

5.2.1 Ưu điểm

- Hệ thống áp dụng mô hình phòng thủ chiều sâu (Defense-in-Depth) với 3 lớp độc lập, giúp tối ưu hóa khả năng bảo mật.
- Sử dụng hoàn toàn các công cụ mã nguồn mở mạnh mẽ (Mosquitto, Suricata, Python), giúp tiết kiệm chi phí triển khai.
- Khả năng giám sát và đưa ra cảnh báo thời gian thực giúp quản trị viên phản ứng nhanh với các nguy cơ xâm nhập.

5.2.2 Nhược điểm

- Việc quản lý chứng chỉ thủ công (Manual PKI) gây khó khăn khi số lượng thiết bị IoT tăng lên quy mô lớn.
- Quá trình bắt tay TLS (Handshake) và việc Suricata phân tích gói tin liên tục có thể gây tiêu tốn tài nguyên đối với các thiết bị có phần cứng cực kỳ hạn chế.

5.3 Hướng phát triển của đề tài

- **Tự động hóa quản lý chứng chỉ:** Nghiên cứu tích hợp các giao thức như ACME hoặc SCEP để tự động cấp phát và gia hạn chứng chỉ cho thiết bị IoT.
- **Phòng thủ chủ động (IPS):** Phát triển khả năng tự động chặn (Block) các địa chỉ IP bị Suricata gắn cờ cảnh báo thông qua tường lửa `iptables` hoặc `nftables`.



- **Tích hợp Machine Learning:** Áp dụng các mô hình học máy vào IDS để phát hiện các hành vi tấn công tinh vi hơn (Anomalies) thay vì chỉ dựa trên dấu hiệu (Signatures).

TÀI LIỆU THAM KHẢO

- [1] **T. Dierks and E. Rescorla (2008).** *RFC 5246: The Transport Layer Security (TLS) Protocol Version 1.2*. Internet Engineering Task Force (IETF).
- [2] **OASIS Standard (2014).** *MQTT Version 3.1.1 Plus Errata 01*. Giao thức truyền tin cho Internet of Things.
- [3] **Suricata Foundation (2024).** *Suricata User Guide Release 7.0.3*. Tài liệu hướng dẫn vận hành hệ thống IDS/IPS mã nguồn mở.
- [4] **Eclipse Foundation (2024).** *Mosquitto Documentation: Authentication and Access Control*. Cấu hình bảo mật dựa trên chứng chỉ cho MQTT Broker.
- [5] **NIST Special Publication 800-52 Rev. 2.** *Guidelines for the Selection, Configuration, and Use of TLS Implementations*.

PHỤ LỤC

A. Môi trường phát triển ứng dụng

Hệ thống được xây dựng và thử nghiệm trên môi trường ảo hóa nhằm đảm bảo tính tương thích và khả năng thực thi các công cụ an ninh mạng chuyên dụng.

- **Phần cứng:** Laptop LAPTOP-AACLUUPG, CPU Intel Core i5, 16GB RAM.
- **Hệ điều hành:** Windows 11 tích hợp WSL2 (Ubuntu 24.04 LTS).
- **Phần mềm mã nguồn mở:**
 - **Eclipse Mosquitto v2.0.18:** MQTT Broker hỗ trợ TLS/M-TLS.
 - **Suricata v7.0.3:** Hệ thống phát hiện xâm nhập (IDS).
 - **Thư viện Paho-MQTT v1.6.1:** Client library cho Python.
 - **Wireshark v4.2.0 & tcpdump:** Công cụ phân tích và bắt gói tin.

B. Cấu trúc cây thư mục nộp bài

Tổ chức thư mục được thực hiện theo đúng quy định của bài tập lớn, bao gồm mã nguồn hiện thực và các tài liệu tham khảo liên quan.

```
Assignment7.zip
├── README.doc ..... Hướng dẫn sử dụng chi tiết
├── report.pdf ..... Báo cáo kỹ thuật
├── srcs ..... Thư mục mã nguồn hiện thực
│   ├── gateway ..... Cấu hình Mosquitto và ACL
│   ├── sensor ..... Mã nguồn Python gửi dữ liệu
│   └── pkis ..... Hệ thống chứng chỉ số TLS/M-TLS
├── refs ..... Tài liệu và mã nguồn mở tham khảo
│   ├── specs ..... Các tiêu chuẩn RFC và OASIS
│   ├── tools ..... Thông tin/Link mã nguồn các công cụ sử dụng
│   ├── btl_iot_capture.pcap ..... Dữ liệu thực nghiệm
│   └── local.rules ..... Bộ quy tắc cho Suricata
```

C. Chi tiết thư mục refs (Tài liệu và Mã nguồn tham khảo)

Thư mục **refs** chứa các tài liệu nền tảng và thông tin về các thư viện mã nguồn mở mà nhóm đã sử dụng để phát triển hệ thống:

1. Tài liệu kỹ thuật (Specifications):

- RFC 5246: Đặc tả về giao thức TLS 1.2.
- OASIS MQTT v3.1.1: Tiêu chuẩn giao thức MQTT.

2. Mã nguồn mở và Thư viện (Open-source Resources):

- Tài liệu hướng dẫn cài đặt và API của *Eclipse Mosquitto*.

- Bộ quy tắc mặc định và hướng dẫn cấu hình của *Suricata IDS*.
- Các mẫu script kết nối an toàn từ dự án *Eclipse Paho*.

3. Dữ liệu minh chứng:

- `btl_iot_capture.pcap`: Bản ghi mạng chứa các gói tin TLS Handshake và Encrypted Application Data thực tế từ hệ thống.